

ZAP by Checkmarx

Scanning Report

Generated with  ZAP on Tue 17 Feb 2026, at 14:19:47

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Contents

- [About This Report](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
 - [Insights](#)
- [Alerts](#)
 - [Risk=High, Confidence=High \(1\)](#)
 - [Risk=High, Confidence=Medium \(5\)](#)

- [Risk=Medium, Confidence=High \(1\)](#)
- [Risk=Medium, Confidence=Medium \(4\)](#)
- [Risk=Medium, Confidence=Low \(1\)](#)
- [Risk=Low, Confidence=High \(3\)](#)
- [Risk=Low, Confidence=Medium \(4\)](#)
- [Risk=Low, Confidence=Low \(1\)](#)
- [Risk=Informational, Confidence=High \(2\)](#)
- [Risk=Informational, Confidence=Medium \(6\)](#)
- [Risk=Informational, Confidence=Low \(1\)](#)
- [Appendix](#)
 - [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <http://192.160.1.66>
- <https://192.168.1.66>

- <https://tracking-protection.cdn.mozilla.net>
- <https://shavar.services.mozilla.com>
- <http://192.168.1.66>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: [User Confirmed](#), [High](#), [Medium](#), [Low](#)

Excluded: [User Confirmed](#), [High](#), [Medium](#), [Low](#), [False Positive](#)

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				Total
		User Confirmed	High	Medium	Low	
Risk	High	0	1	5	0	6

Confidence					
	User				
	Confirmed	High	Medium	Low	Total
	(0.0%)	(3.4%)	(17.2%)	(0.0%)	(20.7%)
Medium	0	1	4	1	6
	(0.0%)	(3.4%)	(13.8%)	(3.4%)	(20.7%)
Low	0	3	4	1	8
	(0.0%)	(10.3%)	(13.8%)	(3.4%)	(27.6%)
Informational	0	2	6	1	9
	(0.0%)	(6.9%)	(20.7%)	(3.4%)	(31.0%)
Total	0	7	19	3	29
	(0.0%)	(24.1%)	(65.5%)	(10.3%)	(100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

Risk					
Site	https://192.16				
		High	Medium	Low	Informational
		(= High)	(>= Medium)	(>= Low)	(>= Informational)
		0	1	0	0

Risk				
	High (= High)	Medium (>= Medium)	Informational	
			Low (>= Low)	Informational (>= Informational)
8.1.66	(0)	(1)	(1)	(1)
https://tracking-protection.cdn.mozilla.net	0 (0)	0 (0)	1 (1)	1 (2)
https://shavar.services.mozilla.com	0 (0)	0 (0)	1 (1)	0 (1)
http://192.168.1.66	6 (6)	5 (11)	6 (17)	8 (25)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Cross Site Scripting (DOM Based)	High	38 (131.0%)
Cross Site Scripting (Persistent)	High	8 (27.6%)
Total		29

Alert type	Risk	Count
Cross Site Scripting (Reflected)	High	1 (3.4%)
Remote OS Command Injection (Time Based)	High	10 (34.5%)
SQL Injection	High	1 (3.4%)
SQL Injection - MySQL	High	1 (3.4%)
Absence of Anti-CSRF Tokens	Medium	5 (17.2%)
Buffer Overflow	Medium	6 (20.7%)
Content Security Policy (CSP) Header Not Set	Medium	5 (17.2%)
Directory Browsing	Medium	5 (17.2%)
HTTP Only Site	Medium	1 (3.4%)
Missing Anti-clickjacking Header	Medium	5 (17.2%)
Cookie No HttpOnly Flag	Low	2 (6.9%)
Cookie without SameSite Attribute	Low	2 (6.9%)
Total		29

Alert type	Risk	Count
In Page Banner Information Leak	Low	1 (3.4%)
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	5 (17.2%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	6 (20.7%)
Strict-Transport-Security Header Not Set	Low	1 (3.4%)
Timestamp Disclosure - Unix	Low	4 (13.8%)
X-Content-Type-Options Header Missing	Low	7 (24.1%)
Authentication Request Identified	Informational	1 (3.4%)
Content-Type Header Missing	Informational	5 (17.2%)
GET for POST	Informational	3 (10.3%)
Information Disclosure - Sensitive Information in URL	Informational	1 (3.4%)
Information Disclosure - Suspicious Comments	Informational	1 (3.4%)
Retrieved from Cache	Informational	5 (17.2%)
Total		29

Alert type	Risk	Count
Session Management Response Identified	Informational	2 (6.9%)
User Agent Fuzzer	Informational	5 (17.2%)
User Controllable HTML Element Attribute (Potential XSS)	Informational	2 (6.9%)
Total		29

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	49
Low	Warning		ZAP warnings logged - see the zap.log file for details	14
Info	Informational	http://192.160.1.66	Percentage of endpoints with content type text/ plain	100 %
Info	Informational	http://192.160.	Percentage of endpoints with	100 %

Level	Reason	Site	Description	Statistic
		1.66	method GET	
Info	Informational	http://192.168.1.66	Count of total endpoints	1
Info	Informational	http://192.168.1.66	Percentage of responses with status code 2xx	63 %
Info	Informational	http://192.168.1.66	Percentage of responses with status code 3xx	19 %
Info	Exceeded Low	http://192.168.1.66	Percentage of responses with status code 4xx	13 %
Info	Informational	http://192.168.1.66	Percentage of responses with status code 5xx	3 %
Info	Informational	http://192.168.1.66	Percentage of endpoints with content type image/gif	2 %
Info	Informational	http://192.168.1.66	Percentage of endpoints with content type image/jpeg	31 %
Info	Informational	http://192.168.1.66	Percentage of endpoints with content type text/css	3 %

Level	Reason	Site	Description	Statistic
Info	Informational	http://192.168.1.66	Percentage of endpoints with content type text/html	52 %
Info	Informational	http://192.168.1.66	Percentage of endpoints with method GET	86 %
Info	Informational	http://192.168.1.66	Percentage of endpoints with method POST	13 %
Info	Informational	http://192.168.1.66	Count of total endpoints	87
Info	Informational	https://192.168.1.66	Percentage of endpoints with method GET	100 %
Info	Informational	https://192.168.1.66	Count of total endpoints	1
Info	Informational	https://shavar.services.mozilla.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://shavar.services.mozilla.com	Percentage of endpoints with content type application/octet-stream	100 %

Level	Reason	Site	Description	Statistic
Info	Informational	https://shavar.services.mozilla.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://shavar.services.mozilla.com	Count of total endpoints	1
Info	Informational	https://shavar.services.mozilla.com	Percentage of slow responses	100 %
Info	Informational	https://tracking-protection.cdn.mozilla.net	Percentage of responses with status code 2xx	100 %
Info	Informational	https://tracking-protection.cdn.mozilla.net	Percentage of endpoints with content type application/octet-stream	100 %
Info	Informational	https://tracking-protection	Percentage of endpoints with method GET	100 %

Level	Reason	Site	Description	Statistic
Info	Informational	on.cdn.mozilla.net https://tracking- protection.cdn.mozilla.net	Count of total endpoints	1
Info	Informational	https://tracking- protection.cdn.mozilla.net	Percentage of slow responses	100 %

Alerts

Risk=High, Confidence=High (1)

<http://192.168.1.66> (1)

Cross Site Scripting (DOM Based) (1)

► GET (* */oNcliCk=alert(5397))//%0D%0A%0d%0a//</stYle/</titLe/</teXtarEa/</scRipt/--!>\x3csVg/<sVg/oNloAd=alert(5397)//>\x3e">http://192.168.1.66#jaVaScRipt:/*-/*`/\*\`/*'/*"/**/(* */oNcliCk=alert(5397))//%0D%0A%0d%0a//</stYle/</titLe/</teXtarEa/</scRipt/--!>\x3csVg/<sVg/oNloAd=alert(5397)//>\x3e

Risk=High, Confidence=Medium (5)

<http://192.168.1.66> (5)

Cross Site Scripting (Persistent) (1)

► GET <http://192.168.1.66/guestbook.php>

Cross Site Scripting (Reflected) (1)

► POST <http://192.168.1.66/users/login.php>

Remote OS Command Injection (Time Based) (1)

► POST <http://192.168.1.66/passcheck.php>

SQL Injection (1)

► GET <http://192.168.1.66/pictures/view.php?picid=14%27+AND+%271%27%3D%271%27+-++>

SQL Injection - MySQL (1)

► POST <http://192.168.1.66/users/login.php>

Risk=Medium, Confidence=High (1)

<http://192.168.1.66> (1)

Content Security Policy (CSP) Header Not Set (1)

- ▶ GET <http://192.168.1.66>

Risk=Medium, Confidence=Medium (4)

<https://192.168.1.66> (1)

HTTP Only Site (1)

- ▶ GET <http://192.168.1.66/>

<http://192.168.1.66> (3)

Buffer Overflow (1)

- ▶ POST <http://192.168.1.66/admin/index.php?page=login>

Directory Browsing (1)

- ▶ GET <http://192.168.1.66/css/>

Missing Anti-clickjacking Header (1)

- ▶ GET <http://192.168.1.66>

Risk=Medium, Confidence=Low (1)

<http://192.168.1.66> (1)

Absence of Anti-CSRF Tokens (1)

- ▶ GET http://192.168.1.66/users/login.php

Risk=Low, Confidence=High (3)

https://tracking-protection.cdn.mozilla.net (1)

Strict-Transport-Security Header Not Set (1)

- ▶ GET https://tracking-protection.cdn.mozilla.net/ads-track-digest256/128.0/1754651396

http://192.168.1.66 (2)

In Page Banner Information Leak (1)

- ▶ GET http://192.168.1.66/favicon.ico

Server Leaks Version Information via "Server" HTTP Response Header Field (1)

- ▶ GET http://192.168.1.66

Risk=Low, Confidence=Medium (4)

http://192.168.1.66 (4)

Cookie No HttpOnly Flag (1)

- ▶ GET http://192.168.1.66

Cookie without SameSite Attribute (1)

- ▶ GET http://192.168.1.66

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (1)

- ▶ GET http://192.168.1.66

X-Content-Type-Options Header Missing (1)

- ▶ GET http://192.168.1.66

Risk=Low, Confidence=Low (1)

https://shavar.services.mozilla.com (1)

Timestamp Disclosure - Unix (1)

- ▶ POST https://shavar.services.mozilla.com/downloads?client=navclient-auto-ffox&appver=128.14&pver=2.2

Risk=Informational, Confidence=High (2)

http://192.168.1.66 (2)

Authentication Request Identified (1)

- ▶ POST http://192.168.1.66/users/login.php

GET for POST (1)

- ▶ GET http://192.168.1.66/users/register.php

Risk=Informational, Confidence=Medium (6)

<https://tracking-protection.cdn.mozilla.net> (1)

Retrieved from Cache (1)

- ▶ GET <https://tracking-protection.cdn.mozilla.net/ads-track-digest256/128.0/1754651396>

<http://192.168.1.66> (5)

Content-Type Header Missing (1)

- ▶ GET <http://192.168.1.66/upload/house/hodjjgld>

Information Disclosure - Sensitive Information in URL (1)

- ▶ GET <http://192.168.1.66/users/sample.php?userid=1>

Information Disclosure - Suspicious Comments (1)

- ▶ GET <http://192.168.1.66/guestbook.php>

Session Management Response Identified (1)

- ▶ GET <http://192.168.1.66>

User Agent Fuzzer (1)

- ▶ GET <http://192.168.1.66/admin>

Risk=Informational, Confidence=Low (1)

<http://192.168.1.66> (1)

User Controllable HTML Element Attribute (Potential XSS) (1)

```
► GET http://192.168.1.66/pictures/view.php?picid=15
```

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

Cross Site Scripting (DOM Based)

Source	raised by an active scanner (Cross Site Scripting (DOM Based))
CWE ID	79
WASC ID	8
Reference	▪ https://owasp.org/www-community/attacks/xss/ ▪ https://cwe.mitre.org/data/definitions/79.html

Cross Site Scripting (Persistent)

Source	raised by an active scanner (Cross Site Scripting (Persistent))
CWE ID	79
WASC ID	8
Reference	▪ https://owasp.org/www-community/attacks/xss/

- <https://cwe.mitre.org/data/definitions/79.html>

Cross Site Scripting (Reflected)

Source

raised by an active scanner ([Cross Site Scripting \(Reflected\)](#))

CWE ID

[79](#)

WASC ID

8

Reference

- <https://owasp.org/www-community/attacks/xss/>
- <https://cwe.mitre.org/data/definitions/79.html>

Remote OS Command Injection (Time Based)

Source

raised by an active scanner ([Remote OS Command Injection \(Time Based\)](#))

CWE ID

[78](#)

WASC ID

31

Reference

- <https://cwe.mitre.org/data/definitions/78.html>
- https://owasp.org/www-community/attacks/Command_Injection

SQL Injection

Source

raised by an active scanner ([SQL Injection](#))

CWE ID

[89](#)

WASC ID

19

Reference

- https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

SQL Injection - MySQL**Source**raised by an active scanner ([SQL Injection](#))**CWE ID**[89](#)**WASC ID**

19

Reference

- https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Absence of Anti-CSRF Tokens**Source**raised by a passive scanner ([Absence of Anti-CSRF Tokens](#))**CWE ID**[352](#)**WASC ID**

9

Reference

- https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html
- <https://cwe.mitre.org/data/definitions/352.html>

Buffer Overflow

Source	raised by an active scanner (Buffer Overflow)
CWE ID	120
WASC ID	7
Reference	▪ https://owasp.org/www-community/attacks/Buffer_overflow_attack

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

Directory Browsing

Source	raised by an active scanner (Directory Browsing)
CWE ID	548
WASC ID	48
Reference	▪ https://httpd.apache.org/docs/current/mod/core.html#options

HTTP Only Site

Source	raised by an active scanner (HTTP Only Site)
CWE ID	311
WASC ID	4
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html ▪ https://letsencrypt.org/

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Cookie No HttpOnly Flag

Source	raised by a passive scanner (Cookie No HttpOnly Flag)
CWE ID	1004
WASC ID	13
Reference	▪ https://owasp.org/www-community/HttpOnly

Cookie without SameSite Attribute

Source	raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID	1275
WASC ID	13
Reference	▪ https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

In Page Banner Information Leak

Source	raised by a passive scanner (In Page Banner Information Leak)
CWE ID	497
WASC ID	13
Reference	▪ https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)

Source	raised by a passive scanner (Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s))
CWE ID	497
WASC ID	13
Reference	▪ https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework ▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

Server Leaks Version Information via "Server" HTTP Response Header Field

Source	raised by a passive scanner (HTTP Server
---------------	---

	Response Header)
CWE ID	497
WASC ID	13
Reference	▪ https://httpd.apache.org/docs/current/mod/core.html#servertokens ▪ https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) ▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

Strict-Transport-Security Header Not Set

Source	raised by a passive scanner (Strict-Transport-Security_Header)
CWE ID	319
WASC ID	15
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html ▪ https://owasp.org/www-community/Security-Headers ▪ https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security ▪ https://caniuse.com/stricttransportsecurity ▪ https://datatracker.ietf.org/doc/html/rfc6797

Timestamp Disclosure - Unix

Source	raised by a passive scanner (Timestamp Disclosure)
CWE ID	497
WASC ID	13
Reference	▪ https://cwe.mitre.org/data/definitions/200.html

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security-Headers

Authentication Request Identified

Source	raised by a passive scanner (Authentication Request Identified)
Reference	▪ https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/

Content-Type Header Missing

Source	raised by a passive scanner (Content-Type Header Missing)
CWE ID	345
WASC ID	12
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)

GET for POST

Source	raised by an active scanner (GET for POST)
CWE ID	16
WASC ID	20

Information Disclosure - Sensitive Information in URL

Source	raised by a passive scanner (Information Disclosure - Sensitive Information in URL)
CWE ID	598
WASC ID	13

Information Disclosure - Suspicious Comments

Source	raised by a passive scanner (Information Disclosure - Suspicious Comments)
CWE ID	615
WASC ID	13

Retrieved from Cache

Source	raised by a passive scanner (Retrieved from Cache)
CWE ID	525
Reference	▪ https://datatracker.ietf.org/doc/html/rfc7234 ▪ https://datatracker.ietf.org/doc/html/rfc7231

- <https://www.rfc-editor.org/rfc/rfc9110.html>

Session Management Response Identified

Source

raised by a passive scanner ([Session Management Response Identified](#))

Reference

- <https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/>

User Agent Fuzzer

Source

raised by an active scanner ([User Agent Fuzzer](#))

Reference

- <https://owasp.org/wstg>

User Controllable HTML Element Attribute (Potential XSS)

Source

raised by a passive scanner ([User Controllable HTML Element Attribute \(Potential XSS\)](#))

CWE ID

[20](#)

WASC ID

20

Reference

- https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html